

Clase 105 — Control de acceso roto: IDOR y path traversal

Parte: 4 — Seguridad de aplicaciones web · Fuente: Real-World Bug Hunting (Yaworski) / OWASP Top 10 A01  Duración estimada: 110 min · Nivel: Avanzado

Objetivo

Explotar el **control de acceso roto (Broken Access Control)**, la categoría número 1 del OWASP Top 10. Nos centramos en **IDOR** (referencias directas inseguras a objetos) y **path traversal** (acceso a archivos fuera del directorio permitido), dos de los hallazgos más frecuentes y rentables en bug bounty.

 **Ética:** solo en labs propios/autorizados. Acceder a datos de otros usuarios reales es un delito.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Detectar** IDOR manipulando identificadores en peticiones.
2. **Diferenciar** control de acceso horizontal y vertical.
3. **Explotar** path traversal para leer archivos del servidor.
4. **Descubrir** funciones administrativas por acceso directo a URLs.
5. **Recomendar** autorización a nivel de objeto y validación de rutas.

Temas

#	Tema	Por qué importa
1	Autorización vertical vs. horizontal	Dos ejes del control roto
2	IDOR clásico	El bug más frecuente
3	IDOR con identificadores no obvios	UUID, hashes, encoding
4	Forced browsing a funciones admin	Acceso directo por URL
5	Path/directory traversal	Lectura de archivos
6	Métodos y verbos HTTP	Bypass por verbo
7	Defensa: authz por objeto	Cierre del fallo

Definiciones y características

- **Broken Access Control:** la app no verifica que el usuario pueda hacer/ver lo solicitado. Característica: categoría A01, la más frecuente.
- **IDOR:** acceder a un objeto cambiando su identificador sin comprobación de permisos. Característica: fácil de detectar cambiando IDs.
- **Autorización horizontal:** acceder a datos de otro usuario del mismo nivel. Característica: IDOR típico.
- **Autorización vertical:** acceder a funciones de mayor privilegio. Característica: escalada a admin.
- **Path traversal:** usar `../` para salir del directorio permitido. Característica: lee archivos arbitrarios del servidor.
- **Forced browsing:** navegar directamente a URLs no enlazadas. Característica: revela funciones sin control de acceso.

Herramientas y preparación

- **Burp** (Intruder para iterar IDs; extensión **Autorize** para probar authz).
- **PortSwigger labs** de access control y **Juice Shop**.
- Dos cuentas de prueba (usuario A y usuario B) para comparar accesos.

Laboratorio guiado

 Solo en labs propios.

1. Auténticate como usuario A y localiza una petición con un ID (`/api/orders/1001`).
2. Cambia el ID a `1002` y observa si accedes a datos de otro usuario (IDOR horizontal).
3. Automatiza con Intruder para enumerar objetos accesibles.
4. Prueba **escalada vertical**: accede a `/admin` o a endpoints de administración con tu sesión normal.
5. Explota **path traversal** en un parámetro de archivo:

```
GET /download?file=../../../../etc/passwd
```

6. Prueba variantes de evasión: encoding (`%2e%2e%2f`), doble encoding, prefijos absolutos.
7. Usa la extensión **Autorize** para detectar automáticamente endpoints sin control de acceso.

Ejercicios

1. Diferencia con ejemplos IDOR horizontal y escalada vertical.
2. Explota un IDOR donde el identificador es un UUID (busca la fuente del UUID).
3. Lee `/etc/passwd` vía path traversal evadiendo un filtro de `../`.
4. Descubre una función admin por forced browsing.
5. Prueba cambiar el verbo HTTP (GET→POST/PUT) para saltar un control.
6. Escribe el control de acceso correcto a nivel de objeto (comprobar propietario).

Reto verificable

Resuelve dos labs de PortSwigger: un **IDOR** que exponga datos de otro usuario y un **path traversal** que lea un archivo del sistema. **Criterio de aceptación:** ambos labs quedan resueltos, documentas el identificador/ruta manipulados, la evidencia del acceso no autorizado y la defensa (authz por objeto, canonicalización de rutas).

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Cambiar el ID da 403	Hay control de acceso; busca otro objeto/verbo
UUID "imposible de adivinar"	Suele filtrarse en otra respuesta; búscalo
../ filtrado	Prueba encoding, doble encoding o rutas absolutas
Admin accesible pero vacío	Falta el rol; prueba acciones concretas
Falso IDOR	Confirma con dos cuentas distintas

? Preguntas frecuentes

? **¿Por qué IDOR es tan común?** Porque los desarrolladores confían en que el ID no es adivinable, en vez de verificar la propiedad del objeto en cada petición.

? **¿Los UUID previenen IDOR?** Dificultan la adivinación, pero no son control de acceso. Si el UUID se filtra, el IDOR persiste.

? **¿Path traversal solo lee archivos?** Leer es lo básico; combinado con upload o LFI puede escalar a ejecución de código en algunos contextos.

Referencias

- Yaworski, *Real-World Bug Hunting*, cap. de IDOR.
- OWASP Broken Access Control (A01): https://owasp.org/Top10/A01_2021-Broken_Access_Control/
- OWASP Path Traversal.
- PortSwigger Access control: <https://portswigger.net/web-security/access-control>

Siguiente clase

Clase 106 - Deserializacion insegura